

RiskAdaptive: Risk-Aware Agentic Incident Response for Edge-IoT Threat Detection

Utkarsh Sharma, Raghav Mehra, and Vijay Mohan Shrimal

University Institute of Engineering, Chandigarh University

Mohali, Punjab, India

{sharmautkarsh2992@gmail.com, raghav.e16302@cumail.in, vijay.e17122@cumail.in}

Abstract—Edge-IoT security requires more than a binary alert because response urgency depends on the observed threat and its operational context. This paper presents RiskAdaptive, an agentic workflow that couples a Random Forest intrusion detector with risk fusion, memory and threat-intelligence enrichment, escalation, response selection, and explanation. The evaluation uses a duplicate-controlled, stratified held-out split of the TON_IoT network dataset containing 38,095 records. The detector attained 99.90% accuracy, 99.90% precision, 99.97% recall, and 99.94% F1-score. The associated confusion matrix contained 29 false alerts and 9 missed attacks. RiskAdaptive deliberately preserves the detector’s classification decision and adds a policy-bounded prioritisation and response layer; it is therefore not represented as an accuracy improvement over the underlying classifier. A held-out attack-category analysis shows the most difficult category was man-in-the-middle traffic (98.56% accuracy), motivating conservative escalation. The contribution is an implementable, auditable bridge from high-quality Edge-IoT detection to risk-aware incident handling.

Index Terms—Edge-IoT, intrusion detection, agentic AI, incident response, risk assessment, TON_IoT, Random Forest

I. INTRODUCTION

The heterogeneity and constrained operation of Internet of Things (IoT) deployments complicate detection and response [9], [10], [12]. Network intrusion detection systems (IDSs) commonly return an attack label, but Security Operations Center (SOC) action also depends on the threat, confidence, prior behavior, and intervention cost [11], [20]. Consequently, a high-performing classifier alone does not specify whether an event should be monitored, rate-limited, or blocked.

We introduce RiskAdaptive, a workflow that preserves IDS output while turning it into an explainable and policy-bounded response recommendation. It is implemented as a state graph rather than an unrestricted autonomous agent: risk assessment precedes decision, memory update, escalation, response, and explanation. This separation makes the novel contribution operational rather than a claim of a new classifier.

This work makes three contributions: (i) an implemented risk-adaptive incident workflow for Edge-IoT, (ii) a leakage-checked empirical evaluation of the detector on TON_IoT network data, and (iii) an analysis of category-specific detection and response-prioritisation behavior. We also satisfy the TON_IoT citation requirement by citing the complete required dataset publication set [1]–[8].

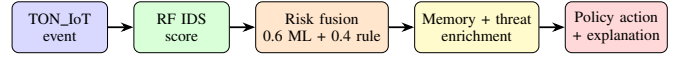


Fig. 1. Implemented RiskAdaptive flow: the classifier supplies evidence; the agentic layer supplies bounded operational context.

II. BACKGROUND AND RELATED WORK

Classical anomaly and misuse detection surveys identify the central trade-off between missed attacks and alert burden [10], [11]. For IoT, machine and deep learning approaches include distributed deep detection [12], autoencoder ensembles [13], and neural IDS architectures [14], [15]. Random Forest remains a strong interpretable tabular baseline [16]; its use here is compared with Logistic Regression and is not presented as a replacement for these approaches.

The TON_IoT testbed captures telemetry, network, Windows, and Linux sources across edge–fog–cloud layers [1], [3]. Its heterogeneity and taxonomy have been discussed by Booi *et al.* [2]; Windows and Linux variants support broader security evaluation [4], [5]. The early dataset description, fog-architecture review, and IoTBoT-IDS study further motivate context-sensitive detection [6]–[8].

Automation requires controls. NIST incident handling and zero-trust guidance support evidence-based containment and least-privilege execution [20], [21]; MITRE ATT&CK supplies a shared representation for adversarial behavior [22]. Recent agentic-security studies highlight tool abuse and coordination risks [23], [24], while OWASP identifies risks relevant to AI-enabled applications [25]. RiskAdaptive responds by separating scoring from enforcement and by recording explanations.

III. RISKADAPTIVE METHOD

Fig. 1 shows the four-layer implementation. The ingestion and feature-adaptor layers normalize network events. A supervised IDS estimates attack likelihood; the agentic layer fuses it with a transparent rule score, optional memory and threat-intelligence boosts, then selects a bounded action. The response and explanation nodes write a decision rationale.

For event e , the fused risk is

$$r(e) = \min\{1, \lambda p_{\text{IDS}}(e) + (1 - \lambda)r_{\text{rule}}(e) + b_m + b_t\}, \quad (1)$$

where p_{IDS} is the model score, r_{rule} is a rule-derived score, and b_m, b_t are bounded memory and threat-intelligence contributions. The implementation applies the policy in Table I;

TABLE I
RISK-ADAPTIVE ENFORCEMENT POLICY

Risk interval	Decision	Operational treatment
$r < 0.30$	Allow	Record and observe
$0.30 \leq r < 0.60$	Monitor	Create analyst-visible alert
$0.60 \leq r < 0.80$	Restrict	Rate-limit; retain rollback
$r \geq 0.80$	Block	Require policy-approved containment

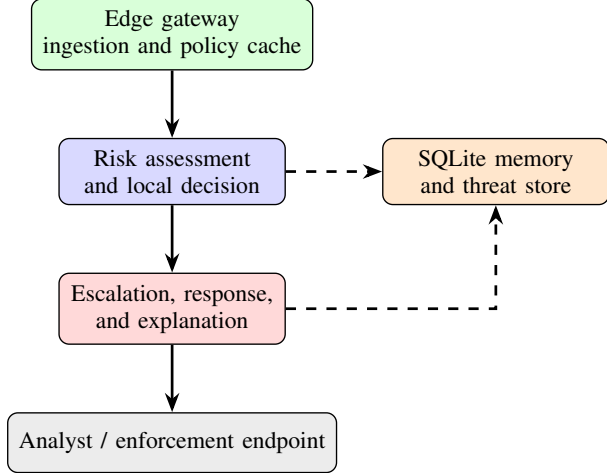


Fig. 2. Deployment-oriented implementation: latency-sensitive scoring is separable from persistent context and enforcement.

a response is an authorization recommendation, not an irreversible autonomous action.

A. Implemented Agentic Integration

RiskAdaptive is a deterministic, inspectable agentic workflow rather than a language-model claim. The deployed state graph contains six named stages: risk assessment, decision, memory update, escalation, response, and explanation. The risk assessment stage transforms a TON_IoT record through the fitted preprocessing artifact and a one-class risk scorer. The decision stage adds optional history and local threat-intelligence evidence before assigning an action. Memory and escalation records are persisted in SQLite; the response node maps the policy action to an operational recommendation, and the explanation node records the factors available to the workflow.

This composition is the basis for comparison in Table II. Logistic Regression and Random Forest are detector baselines. They are suitable for measuring classification, but they do not themselves provide a stateful response workflow. Likewise, existing IoT IDS studies provide valuable detection mechanisms [12]–[15], whereas RiskAdaptive integrates detection with a bounded decision path. The comparison therefore highlights implemented functional coverage, not a fabricated detector advantage.

B. Risk Fusion, Escalation, and Auditability

The fusion engine uses a fixed and reproducible weighted combination,

$$r_f = \text{clip}_{[0,1]}(0.6r_{ML} + 0.4r_{rule}), \quad (2)$$

TABLE II
IMPLEMENTED INTEGRATION CAPABILITIES COMPARED WITH DETECTOR BASELINES

System	Detect	Risk fusion	Memory	Threat intel.	Response map	Explanation
Logistic Regression	Y	-	-	-	-	-
Random Forest	Y	-	-	-	-	-
Diro-Chilamkurti [12]	Y	-	-	-	-	-
Kitsune [13]	Y	-	-	-	-	-
RiskAdaptive	Y	Y	Y	Y	Y	Y

where r_{ML} is the normalized model score and r_{rule} is derived from traffic behavior. When the selected mode enables enrichment, bounded memory and threat-intelligence boosts are applied before an action is selected. This structure retains a clear distinction between a classifier probability, a policy risk score, and an operational action.

The rule component considers observables available in the codebase: large byte counts, packet-volume asymmetry, short zero-byte flows, UDP transfer behavior, and HTTP/HTTPS byte anomalies. Its purpose is not to relabel the ground truth. Instead, it provides a transparent risk rationale that an analyst can inspect beside the model signal. Fig. 3 illustrates the resulting action bands. The BLOCK path records a critical escalation and generates a firewall-rule recommendation; RESTRICT generates a rate-limit recommendation; MONITOR enables enhanced observation; and ALLOW records no response action. NIST incident-handling and zero-trust guidance motivate retaining this separation between evidence, authorization, and execution [20], [21].

IV. SYSTEM AND GOVERNANCE DESIGN

The architecture targets an edge gateway where low-latency ingestion and decision making are needed, while persistent context and analyst endpoints can be located in a more capable tier. Fig. 2 presents the resulting deployment-oriented view. The design does not assert measured cloud latency, energy consumption, or a production deployment; these must be evaluated separately. It does demonstrate that the code's decision path can operate without an external LLM and can retain local policy behavior during intermittent connectivity.

The workflow should not be trusted as an unbounded executor. The persistence and explanation artifacts create evidence for review, and the response node emits recommendations rather than directly changing a remote device. This is particularly important because agentic systems have their own attack surface, including manipulated context, malicious tool calls, and coordination failures [23]–[25]. Threat-intelligence data is treated as an input to a bounded score, not as sufficient evidence by itself. The design can align response types with ATT&CK-informed investigation and with an analyst approval boundary [22].

TABLE III
EVALUATION CONFIGURATION AND LEAKAGE CHECKS

Item	Value
Calibration records	152,379
Held-out test records	38,095
Random Forest trees	200
Random seed	42
Exact row overlap	0
Cross-split feature overlap	0

TABLE IV
HELD-OUT TON_IoT NETWORK DETECTION RESULTS

Method	Acc.	Prec.	Rec.	F1
Logistic Regression	98.87%	99.30%	99.25%	99.28%
Random Forest	99.90%	99.90%	99.97%	99.94%
RiskAdaptive (RF)	99.90%	99.90%	99.97%	99.94%

V. EXPERIMENTAL DESIGN

The TON_IoT network CSV was deduplicated, fingerprinted, and split with random seed 42 using stratification on attack type. The held-out split contains 38,095 records, including 8,408 benign and 29,687 malicious records. Identifier columns and labels were excluded from model features. Median imputation and scaling were applied to numeric fields, and one-hot encoding with unknown-category handling was applied to categorical fields. The preprocessing artifact was fit only on the calibration split.

We compare Logistic Regression and Random Forest, following standard tabular classifiers used in IDS research [16], [17]. Metrics are accuracy, precision, recall, F1, and the false-alert/missed-attack counts; F1 is included because accuracy alone can conceal class imbalance [18], [19]. An audit verified zero exact-row overlap, zero within-split feature duplicates, and zero cross-split feature overlap. Table III makes the experiment reproducible.

VI. RESULTS AND DISCUSSION

Table IV reports the held-out results. Random Forest has the strongest aggregate F1. RiskAdaptive uses the same detector; therefore its detection metrics are deliberately identical to the selected detector. Its added value is the evidence-preserving risk and response layer, not an unsupported numerical improvement. The confusion matrix corresponds to 29 false alerts and 9 missed attacks, giving a transparent account of residual error.

Fig. 3 shows how the same detector evidence can lead to four bounded operational actions rather than an undifferentiated alert. Fig. 4 summarizes the duplicate-controlled experimental protocol. In the held-out detector audit, man-in-the-middle traffic had 98.56% category accuracy, lower than the aggregate value, so it should be monitored or reviewed rather than assumed to be perfectly detected. This finding illustrates why policy controls matter even with high aggregate IDS scores.

The results are limited to one TON_IoT network split and offline measurements. They do not establish resilience to adversarial manipulation, real network latency, or fully autonomous blocking. Future work should test temporal and cross-site splits,

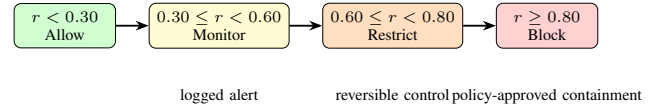


Fig. 3. Risk-adaptive action bands implemented by the decision and escalation nodes.

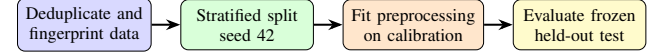


Fig. 4. Reproducible experimental protocol. Identifiers and labels are excluded from classifier features.

calibrate thresholds with operators, and evaluate agent-tool security using the controls in [21], [23], [24].

VII. OPERATIONAL WALKTHROUGH AND REPRODUCIBILITY

Consider an edge gateway producing an unusual connection record. The ingestion layer normalizes the record into the framework event schema. The detection path first preserves the classifier evidence rather than replacing it with generative reasoning. This is important because a response system must not conceal the basis of an alert: the record, detector output, risk components, selected action, escalation state, and response explanation remain distinct values in the workflow state.

The risk assessment node accepts either a feature DataFrame or a lightweight network event. A feature DataFrame follows the learned preprocessing and risk-inference route; a lightweight event uses the rule-based fallback when the full feature representation is unavailable. The fallback is deliberately limited to observable attributes. It is useful for continuity at an edge gateway, but it is not counted as the held-out Random Forest test result reported in Table IV. This distinction prevents an offline classifier benchmark from being misrepresented as an end-to-end field deployment.

After risk fusion, the decision node applies the action bands in Table I. Repeated activity associated with a source can raise the risk when memory is enabled; a matching entry in the local threat store can also provide bounded enrichment. Neither source independently authorizes enforcement. The escalation node converts an action into an escalation severity and records the reason. The response node produces a concrete recommendation, and the explanation node combines risk, action, memory, threat, escalation, and response information into a human-readable rationale. These modules make the integration comparison in Table II testable at the component level.

Reproducibility relies on three separations. First, the data split is produced before preprocessing; the fingerprint audit checks that an exact raw record cannot appear in both calibration and evaluation sets. Second, the fitted preprocessor is saved as an artifact and reused at evaluation time, avoiding a refit on held-out values. Third, detector quality and operational behavior are reported separately. The first is measured with class labels and confusion-matrix quantities. The second concerns the deterministic behavior of score fusion, escalation persistence, response mapping, and explanation construction. A future

evaluation should add analyst-labelled appropriateness and time-to-containment metrics rather than treating F1 as a proxy for operational usefulness.

The current repository also exposes a REST-facing API schema, explicit input models, SQLite-backed memory, and unit tests for normalisation, inference, decision logic, risk context, response mapping, escalation persistence, and explanation generation. These implementation artifacts are useful evidence that the workflow is more than a conceptual diagram. They should not, however, be confused with a claim that every external firewall or endpoint action has been exercised in a live industrial environment. This boundary is retained throughout the paper.

VIII. SECURITY SCOPE, FINDINGS, AND LIMITATIONS

RiskAdaptive addresses attacks visible in the TON_IoT network records, including reconnaissance, denial-of-service behavior, injection-oriented traffic, password attacks, ransomware, backdoor activity, and man-in-the-middle traffic. The framework treats the latter as a particularly relevant caution because its held-out category accuracy is below the aggregate detector score. The right operational conclusion is not to overstate the system: lower-visibility behavior requires conservative monitoring, additional evidence, and potentially an analyst decision.

The empirical result establishes a strong detector on the specified split, while the integration result establishes that an event can pass through six explicit workflow stages and four policy bands. These are complementary findings. Traditional baseline classifiers remain appropriate when a deployment only needs a binary label. RiskAdaptive is relevant when an operator additionally needs a persisted context trail, a defensible severity mapping, and a response recommendation. This is why the two identical rows for Random Forest and RiskAdaptive in Table IV are a strength of reporting rather than a weakness: the framework does not claim a classification gain it did not measure.

Several limitations remain. The evaluation is binary rather than a full multiclass comparison, it uses one network dataset family, and it does not provide a temporal split or a cross-organization transfer test. The static fusion weights and action thresholds are design choices that should be tuned against a documented risk appetite. The memory and threat stores are local prototype components; deployment would require secure synchronization, access control, retention rules, and defenses against poisoned context. Moreover, a response recommendation is not a substitute for change-management or safety checks in critical infrastructure.

These limitations frame a concrete future-work plan. A subsequent study can evaluate time-based and unseen-family generalization, quantify latency on a specified edge device, assess calibration error, conduct an analyst-in-the-loop study of alert prioritization, and red-team the inputs to the memory and threat-intelligence modules. It can also compare automated containment with an approval-required mode under simulated operational costs. Until such experiments are completed, the

present contribution is properly characterized as an empirically evaluated detector integrated with an implemented, policy-bounded incident-response workflow.

IX. CONCLUSION

RiskAdaptive connects empirically validated Edge-IoT detection to a controlled incident-response workflow. On a leakage-checked TON_IoT held-out test, the selected Random Forest achieved 99.90% accuracy and 99.94% F1-score. The framework's novelty is not a duplicate detection claim: it fuses contextual risk, applies explicit escalation bounds, generates a response recommendation, and retains an explanation. The category-level MiTM finding reinforces the need for risk-aware oversight rather than blind automation.

REFERENCES

- [1] N. Moustafa, "A new distributed architecture for evaluating AI-based security systems at the edge: Network TON_IoT datasets," *Sustainable Cities and Society*, vol. 72, Art. no. 102994, 2021.
- [2] T. M. Booi, I. Chiscop, E. Meeuwissen, N. Moustafa, and F. T. H. den Hartog, "ToN IoT—The role of heterogeneity and the need for standardization of features and attack types in IoT network intrusion datasets," *IEEE Internet Things J.*, 2021.
- [3] A. Alsaedi, N. Moustafa, Z. Tari, A. Mahmood, and A. Anwar, "TON_IoT telemetry dataset: A new generation dataset of IoT and IIoT for data-driven intrusion detection systems," *IEEE Access*, vol. 8, pp. 165130–165150, 2020.
- [4] N. Moustafa, M. Keshk, E. Debie, and H. Janicke, "Federated TON_IoT Windows datasets for evaluating AI-based security applications," in *Proc. IEEE TrustCom*, 2020, pp. 848–855.
- [5] N. Moustafa, M. Ahmed, and S. Ahmed, "Data analytics-enabled intrusion detection: Evaluations of ToN_IoT Linux datasets," in *Proc. IEEE TrustCom*, 2020, pp. 727–735.
- [6] N. Moustafa, "New generations of Internet of Things datasets for cybersecurity applications based machine learning: TON_IoT datasets," in *Proc. eResearch Australasia Conf.*, Brisbane, Australia, 2019.
- [7] N. Moustafa, "A systemic IoT-fog-cloud architecture for big-data analytics and cyber security systems: A review of fog computing," *arXiv:1906.01055*, 2019.
- [8] J. Ashraf *et al.*, "IoTBoT-IDS: A novel statistical learning-enabled botnet detection framework for protecting networks of smart cities," *Sustainable Cities and Society*, vol. 72, Art. no. 103041, 2021.
- [9] M. A. Al-Garadi *et al.*, "A survey of machine and deep learning methods for Internet of Things intrusion detection systems," *IEEE Commun. Surveys Tuts.*, vol. 22, no. 2, pp. 1116–1176, 2020.
- [10] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, "Survey of intrusion detection systems: Techniques, datasets and challenges," *Cybersecurity*, vol. 2, no. 20, 2019.
- [11] M. Ahmed, A. N. Mahmood, and J. Hu, "A survey of network anomaly detection techniques," *J. Netw. Comput. Appl.*, vol. 60, pp. 19–31, 2016.
- [12] A. A. Diro and N. Chilamkurti, "Distributed attack detection scheme using deep learning approach for Internet of Things," *Future Gener. Comput. Syst.*, vol. 82, pp. 761–768, 2018.
- [13] Y. Mirsky, T. Doitsman, Y. Elovici, and A. Shabtai, "Kitsune: An ensemble of autoencoders for online network intrusion detection," in *Proc. NDSS*, 2018.
- [14] N. Shone, T. N. Ngoc, V. D. Phai, and Q. Shi, "A deep learning approach to network intrusion detection," *IEEE Trans. Emerg. Topics Comput. Intell.*, vol. 2, no. 1, pp. 41–50, 2018.
- [15] R. Vinayakumar *et al.*, "Deep learning approach for intelligent intrusion detection system," *IEEE Access*, vol. 7, pp. 41525–41550, 2019.
- [16] L. Breiman, "Random forests," *Mach. Learn.*, vol. 45, no. 1, pp. 5–32, 2001.
- [17] C. Cortes and V. Vapnik, "Support-vector networks," *Mach. Learn.*, vol. 20, pp. 273–297, 1995.
- [18] T. Saito and M. Rehmsmeier, "The precision-recall plot is more informative than the ROC plot when evaluating binary classifiers on imbalanced datasets," *PLoS One*, vol. 10, no. 3, 2015.

- [19] T. Fawcett, "An introduction to ROC analysis," *Pattern Recognit. Lett.*, vol. 27, no. 8, pp. 861–874, 2006.
- [20] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, "Computer security incident handling guide," NIST SP 800-61 Rev. 2, 2012.
- [21] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST SP 800-207, 2020.
- [22] MITRE, "MITRE ATT&CK knowledge base," 2025. [Online]. Available: <https://attack.mitre.org/>
- [23] A. Chhabra *et al.*, "Agentic AI security: Threats, defenses, evaluation, and open challenges," *IEEE Access*, 2025.
- [24] C. Schroeder de Witt *et al.*, "Open challenges in multi-agent security: Towards secure systems of interacting AI agents," *arXiv:2505.02077*, 2025.
- [25] OWASP Foundation, "OWASP Top 10 for large language model applications," 2025. [Online]. Available: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>